

Jour 1

Comprendre l'ANSSI et qualifier PortNormand

Situation	Mission de l'ANSSI	Autre acteur possible
Intrusion détectée sur la supervision SCADA d'un terminal pétrolier	Détecter et réagir : réception de la notification, assistance technique (CERT-FR)	Ministère des Transports (coordination sectorielle)
Fuite de données personnelles d'agents ou de clients	Appui technique éventuel	CNIL (notification de violation, 72 h)
Choisir un prestataire pour un audit de sécurité	Qualifier les prestataires (PASSI) et tenir l'annuaire	Aucun autre régulateur, mais le prestataire lui-même
Héberger le Port Community System chez un fournisseur cloud	Qualifier (SecNumCloud)	DINUM, doctrine cloud de l'État (selon le cas)
Vérifier que PortNormand applique ses obligations LPM/NIS2	Contrôler (audits, contrôles de conformité)	Ministère de tutelle (Transports)
Former et sensibiliser les agents de la DSI et de la nouvelle cellule sécurité	Informar, former, sensibiliser (guides, SecNumAcadémie)	Cybermalveillance.gouv.fr (plutôt PME, collectivités, particuliers)
Acheter un pare-feu ou un produit de sécurité fiable	Certifier les produits (CSPN, Critères Communs)	Organismes d'évaluation agréés (CESTI)
Déposer plainte après une attaque par rançongiciel	Aucune (l'ANSSI ne mène pas d'enquête judiciaire)	Police, gendarmerie, parquet
Soupçon d'espionnage par un acteur étatique	Assistance technique et analyse de la menace	DGSI (contre-ingérence)
Incident touchant aussi l'opérateur européen racheté (transfrontalier)	Point de contact national et coopération européenne	ENISA, CSIRT des autres États

Les lignes 8 et 9 sont utiles : elles montrent ce que l'ANSSI ne fait pas. Ca évite une erreur classique : celle de tout lui attribuer.

Note de qualification du statut réglementaire de PortNormand

| Date : 30/09/2026

1. Statut retenu

PortNormand est aujourd'hui Opérateur d'Importance Vitale (OIV) du secteur Transports et relève à ce titre de la loi de programmation militaire (article 22 de la loi n° 2013-1168). Il sera très probablement qualifié d'entité essentielle au sens de la directive NIS2 (UE 2022/2555) dès que celle-ci sera transposée. Les deux régimes devront être traités en parallèle.

2. Arguments

Régime OIV (en vigueur). PortNormand est désigné OIV depuis 2015. Il est donc tenu de déclarer ses systèmes d'information d'importance vitale (SIIV), d'appliquer les règles de sécurité sectorielles, de notifier ses incidents à l'ANSSI, d'accepter ses contrôles et de recourir à des produits et prestataires qualifiés. La supervision SCADA des terminaux (notamment pétroliers) est un candidat évident au statut de SIIV.

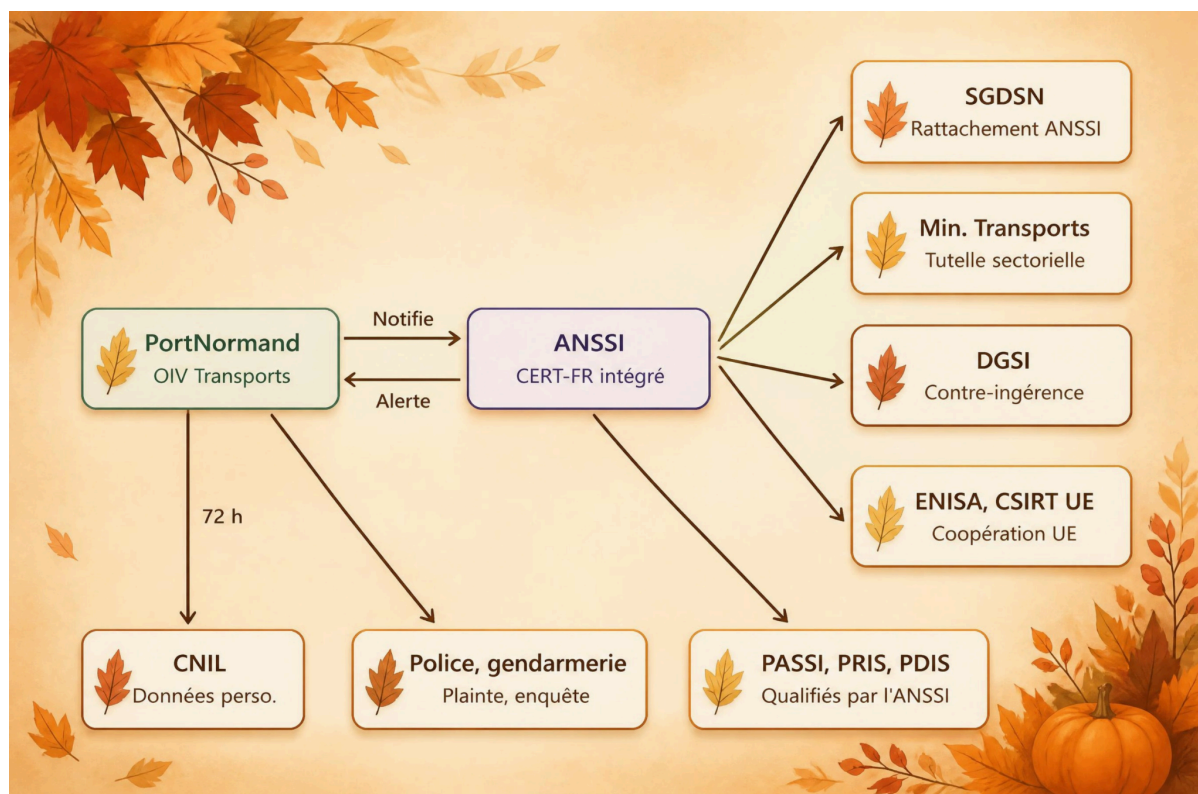
Régime NIS2 (à venir). Les ports et la gestion du trafic maritime relèvent des secteurs de l'annexe I de NIS2 (transports par voie d'eau). Avec 1 200 agents et 340 M€ de CA consolidé, PortNormand dépasse les seuils des grandes entreprises (250 personnes ou 50 M€ de CA). Il correspond donc à la catégorie « entité essentielle » et non « importante ».

État de la transposition. La France n'avait pas achevé la transposition de NIS2 au 6 août 2026, via le projet de loi Résilience. Ce projet de loi est inscrit à l'ordre du jour de l'Assemblée nationale début octobre 2026. NIS2 n'est donc pas encore applicable : le courrier de l'ANSSI prépare la bascule, sans supprimer les obligations LPM actuelles.

[nis-2-directiveassemblee-nationale](#)

3. Incertitudes identifiées

- Chiffres incohérents dans le sujet : « 1 200 agents » avant l'acquisition, puis « effectif consolidé 1 200 pers. » après. La conclusion ne change pas (les seuils sont largement dépassés), mais les données sont à confirmer.
- Opérateur logistique européen racheté : son statut dépend de son pays d'établissement et de son activité (transport multimodal). Il peut relever d'un autre État membre.
- Cadre juridique non finalisé : la loi n'est pas promulguée et les décrets d'application n'existent pas encore. Les obligations précises (mesures de sécurité, délais de notification, sanctions) et l'articulation entre régime OIV et NIS2 restent à confirmer.
- Périmètre des systèmes : il reste à déterminer quels systèmes sont des SIIV (OIV) et lesquels relèvent de NIS2 (Port Community System, radio VHF, vidéoprotection).



Fiche acteurs (acteur / mission / exemple)

Acteur	Mission	Exemple chez PortNormand
ANSSI	Autorité nationale de sécurité et de défense des systèmes d'information : réguler, qualifier, accompagner, contrôler	Contrôle des SIIV ; courrier d'accompagnement NIS2
CERT-FR (au sein de l'ANSSI)	Veille, alerte et réponse aux incidents ; publie avis et alertes de sécurité	Reçoit la notification d'intrusion sur le SCADA et oriente la réponse
SGDSN	Service du Premier ministre qui coordonne la défense et la sécurité nationale ; l'ANSSI lui est rattachée	Cadre interministériel de la politique OIV, coordination en cas de crise majeure
Ministère des Transports (HFDS)	Ministre coordonnateur du secteur : règles sectorielles et interlocuteur de tutelle	Être informé si un terminal est à l'arrêt
CNIL	Autorité de protection des données personnelles (RGPD) : reçoit les notifications de violation sous 72 h	Fuite de données d'agents ou de clients via le Port Community System
DGSI	Contre-ingérence et lutte contre l'espionnage	Intrusion attribuée à un acteur étatique

Police /
gendarmerie /
parquet

Enquête judiciaire, réception des
plaintes

Plainte après un rançongiciel

ENISA / CSIRT
européens

Coopération et appui à l'échelle de
l'UE

Incident touchant aussi la filiale
européenne

Prestataires
qualifiés (PASSI,
PRIS, PDIS)

Audit, réponse à incident et
détection, avec qualification délivrée
par l'ANSSI

PASSI pour auditer le SCADA,
PRIS pour gérer un incident

Jour 2

En l'absence du scénario officiel, nous retenons l'hypothèse suivante : un rançongiciel chiffre le Port Community System (PCS) de PortNormand. Une activité suspecte est détectée sur le réseau de supervision SCADA d'un terminal pétrolier, qui est isolé par précaution (aucun impact sur la sécurité des personnes). Une exfiltration de données personnelles (agents, transporteurs) est possible mais non confirmée.

Frise de notification (qui / quoi / quand)

Quand	Qui	Quoi
T0	SOC / DSI	Détection : fichiers chiffrés sur le PCS, alerte sur le segment SCADA
T0 + 1 h	RSSI + cellule sécurité	Qualification : rançongiciel, systèmes touchés, SIIV potentiellement concerné
T0 + 1 h 30	RSSI → direction	Alerte de la direction, activation de la cellule de crise, isolement du SCADA
T0 + 2 h	RSSI → ANSSI / CERT-FR	Notification de l'incident « sans délai » et demande d'assistance
T0 + 2 h	Direction → ministère des Transports (HFDS)	Information de la tutelle sectorielle
T0 + 4 h	RSSI → prestataire PRIS	Mobilisation pour l'investigation et la remédiation
Avant T0 + 72 h	DPO → CNIL	Notification de violation, si l'exfiltration est confirmée ou probable
Sous 72 h	Direction → police / gendarmerie	Dépôt de plainte
Après la crise	RSSI → ANSSI	Rapport complémentaire et retour d'expérience

Les heures sont indicatives ; c'est les heures et les destinataires qui comptent, pas les durées exactes.

Brouillon du message de notification (13 lignes)

Objet : Déclaration d'incident de sécurité, PortNormand (OIV Transports)

À : ANSSI / CERT-FR | **Cc :** ministère chargé des Transports (HFDS)

De : [Ton nom], RSSI de PortNormand, [téléphone sécurisé]

1. Détection le 10/01/2026 à 14 h 20 par notre SOC : chiffrage de fichiers sur le Port Community System.
2. Nature présumée : rançongiciel ; une demande de rançon a été reçue.
3. Systèmes affectés : PCS (indisponible) ; activité suspecte sur le réseau de supervision SCADA du terminal pétrolier.

4. Systèmes d'importance vitale : le SCADA du terminal est un SIIV potentiellement concerné ; sa compromission n'est pas confirmée.
5. Impact : gestion des escales perturbée ; terminal pétrolier passé en mode dégradé par précaution.
6. Sécurité des personnes et des installations : aucun risque identifié à ce stade.
7. Données : exfiltration de données personnelles possible, en cours d'analyse.
8. Actions engagées : isolement du segment SCADA, cellule de crise activée, sauvegardes préservées.
9. Origine : inconnue, investigation en cours.
10. Éléments techniques (journaux, indicateurs de compromission) disponibles via un canal sécurisé.
11. Assistance demandée : analyse technique et recommandations de remédiation.
12. Prochain point : à 18 h, puis rapport complémentaire sous 72 h.
13. Contact opérationnel 24/7 : [nom, téléphone...].

Tableau besoin / qualification / justification

Besoin	Qualification	Justification
Auditer la sécurité du SCADA des terminaux et des systèmes d'importance vitale	PASSI (prestataire d'audit)	Les audits de SIIV sont à confier à un prestataire qualifié, ce qui garantit des compétences et une méthode reconnues par l'ANSSI
Détecter les attaques en continu (SOC, SIEM) sur les SIIV	PDIS (prestataire de détection)	Les règles sectorielles OIV imposent des moyens de détection ; faire appel à un prestataire qualifié est la voie standard si PortNormand ne l'opère pas lui-même
Répondre à un rançongiciel comme dans notre scénario	PRIS (prestataire de réponse aux incidents)	Investigation, confinement et remédiation par un prestataire qualifié, mobilisable rapidement (cf. exercice 4)
Héberger le Port Community System chez un fournisseur cloud	SecNumCloud	Garantit un niveau de sécurité et de protection contre les lois extra-européennes, adapté à des données et services sensibles
Acheter un pare-feu, une sonde ou un autre produit de sécurité	Certification CSPN ou Critères Communs (produit qualifié)	Les produits de sécurité des SIIV doivent être évalués, la certification atteste de leur robustesse
Se faire accompagner pour la gouvernance, l'analyse de risques et la mise en conformité NIS2	PACS (prestataire d'accompagnement et de conseil)	Qualification en conseil, utile pour structurer la conformité d'une cellule sécurité récente (8 personnes)

Pour la colonne “qualification exigée”, je distingue ce qui est exigé de ce qui est recommandé. C’est une nuance : par exemple, la qualification est imposée pour la détection et l’audit sur les

SIIV, mais le recours à un PACS ou à un SecNumCloud dépend de la sensibilité et du choix de PortNormand.

Plan d'action : préparation à un contrôle de conformité de l'ANSSI

Niveaux estimés d'après les éléments du cas (à confirmer par un état des lieux interne).

1. Points de contrôle et niveau de préparation

Point de contrôle	Niveau estimé	Commentaire
Désignation OIV et déclaration des SIIV à jour	Bon	OIV depuis 2015 ; périmètre à revalider après l'acquisition
PSSI et organisation de la sécurité (RSSI, rôles, gouvernance)	Moyen	Cellule sécurité de 8 personnes, récemment créée
Cartographie et inventaire des SI (SCADA, PCS, VHF, vidéoprotection, filiale)	Faible	Intégration de l'opérateur racheté en cours
Homologation des SIIV	À vérifier	Existence et date des décisions d'homologation
Règles de sécurité sectorielles (cloisonnement IT/OT, accès, journalisation)	Moyen	Enjeu fort sur la supervision SCADA
Détection des incidents (SOC, prestataire PDIS)	Moyen	Couverture des SIIV à confirmer
Procédure de notification d'incident à l'ANSSI	Faible	Personne ne sait précisément qui contacter
Audits de sécurité (PASSI) et suivi des écarts	À vérifier	Dernier audit, plan de remédiation
Produits et prestataires qualifiés	Moyen	Cf. exercice 5
Continuité d'activité (PCA/PRA) et exercices de crise	Moyen	Test récent à documenter

2. Trois actions prioritaires

1. **Formaliser la notification d'incident** : désigner un point de contact ANSSI et un suppléant, rédiger la procédure (qui, quoi, quand) et la tester par un exercice de crise.
Pilote : RSSI. Échéance : 1 mois.

2. **Cartographier les systèmes et confirmer le périmètre des SIIV**, filiale incluse, et clarifier ce qui relève de la LPM aujourd'hui et de NIS2 demain. *Pilote : DSI + cellule sécurité. Échéance : 3 mois.*
3. **Lancer un audit par un prestataire PASSI** sur les SIIV et le SCADA, avec un plan de remédiation priorisé. *Pilote : RSSI + direction. Échéance : 3 à 6 mois.*

QCM

- **PASSI : Prestataire d'Audit de la Sécurité des Systèmes d'Information**
- **PDIS : Prestataire de Détection des Incidents de Sécurité**
- **PRIS : Prestataire de Réponse aux Incidents de Sécurité**
- **PACS : Prestataire d'Accompagnement et de Conseil en Sécurité**
- **SecNumCloud : référentiel de qualification des fournisseurs de services cloud**